



Security/Compliance KPIs & KRIs

WHAT:

- Security KPIs will be used to track progress and improvements in relationship with security inside engineering and SSDLC.
- KRIs are designed to monitor and provide early warnings about potential risks and threats to an organization.
- KRIs will be shared with RCC committee

WHEN : KPIs and KRIs will be calculated quarterly.

HOW : JIRA and Snyk/SonarQube (SAST/SCA tool) will be used to get the required input data.

WHY :

- KPIs are used to define a baseline and target improvements in key security engineering areas (planning to define security KPIs also outside engineering). The KPIs are also part of Security department OKRs.
- KRIs are used to assess the likelihood and impact of risks and to enable proactive risk management strategies.

KPI and KRIs calculation

[KPIs and KRIs.xlsx](#)

Q4 2022

ID	KPI name	KPI Description	Q4 Calculated value	Q4 2022 Target
KP01	# of vulnerabilities failing remediation Security Team SLAs	Calculates the number of vulnerabilities that are failing to comply with the agreed remediation SLAs (per risk severity)	Critical-0 High-0% Medium- 46% Low-23%	Critical - 0% High - 25% Medium - 50% Low - 100%
KP02	# of vulnerabilities per 1k lines of code	Calculates the number of vulnerabilities per 1k lines of code	See below table	See below table
KP03	# of reported vulnerabilities disclosures not known internally	Calculates the number of reported vulnerabilities disclosure that were not previously identified internally	6 reported, 0 unknown	0 unknown
KR01	% of employees who click on phishing emails.	Measures the effectiveness of security awareness training and the organization's susceptibility to social engineering attacks.	11%	15%
KR02	# of unsuccessful login attempts or unauthorized access incidents.	Highlights potential brute-force attacks or unauthorized access attempts	0	0
KR03	The financial impact of a data breach per compromised record.	Quantifies the potential financial loss associated with a data breach.	0	0
KR04	# of Insider Threat Incidents	Highlights potential insider threats and the effectiveness of insider threat detection mechanisms.	0	0
KR05	% of time systems are available and operational.	Reflects the resilience of the organization's IT infrastructure and the potential impact of downtime on security.	>99%	99%

*The percentage for Low security vulnerability is within the target not because the vulnerabilities were addressed, but because the SLA for Low vulnerabilities is 12 weeks and it was not reached for majority of them.

Notes:

- KP01 takes into account only the JIRA raised security tickets (Snyk reported issues were not included)

S02 KPI calculation

Squad name	Sum of LOC	# of vuln				#of vulns/1k Loc (total count)					Target Q42022			
		Critical	High	Medium	Low	Critical	High	Medium	Low	Total	Critical	High	Medium	Low
D&I	29448	0	14	13	47	0.00	0.48	0.44	1.60	2.51	0.1	1	2	4
Central Platform	24400	3	37	50	73	0.12	1.52	2.05	2.99	6.68				
Payments	15800	0	2	2	21	0.00	0.13	0.13	1.33	1.58				
Connections	128200	0	133	87	215	0.00	1.04	0.68	1.68	3.39				
LinkSDK	15000	0	4	21	4	0.00	0.27	1.40	0.27	1.93				
DevOps	10000	0	8	37	12	0.00	0.80	3.70	1.20	5.70				

Notes:

- Snyk reported vulnerabilities are included , however they are not triaged or risk score reassessed. A 10% of false positives (as per expected FP rate) was removed from the calculation
- Target is set as per best practices with color schema showing
 - Red - target is not met
 - Yellow - target is close to be met
 - Green-Target is met

Identified Opportunities for Improvement based on KPIs and KRIs values

- Identify which vulnerabilities are more frequently introduced as part of the code base and provide tailored security training to developers during next quarter
 - Access Control vulnerabilities
 - Injection Flaws
- Analyze the root cause of the achieved service downtime during Q4 2022 and improve the monitoring and alerting
 - -Improve on Kafka's stability

Q1 2023

ID	KPI name	KPI Description	Q4 2022 value	Q1 2023 Calculated value	Target value
KP01	# of vulnerabilities failing remediation Security Team SLAs	Calculates the number of vulnerabilities that are failing to comply with the agreed remediation SLAs (per risk severity)	Critical - 0% High - 0% Medium - 46% Low - 23%	Critical - 0% High - 0% Medium - 62% Low - 75%	Critical - 0% High - 25% Medium - 50% Low -75%
KP02	# of vulnerabilities per 1k lines of code	Calculates the number of vulnerabilities per 1k lines of code		See below table	See below table
KP03	# of reported vulnerabilities disclosures not known internally	Calculates the number of reported vulnerabilities disclosure that were not previously identified internally	N/A	4 reported, 0 unknown	0 unknown
KP04	% of software developers that have taken security training in the past quarter	% of software developers that have taken security training in the past 12 months	N/A	90%	100%
KR01	% of employees who click on phishing emails.	Measures the effectiveness of security awareness training and the organization's susceptibility to social engineering attacks.	25%	15%	
KR02	# of unsuccessful login attempts	Highlights potential brute-force attacks or	0	0	

ID	KPI name	KPI Description	Q4 2022 value	Q1 2023 Calculated value	Target value
	or unauthorized access incidents.	unauthorized access attempts			
KR03	The financial impact of a data breach per compromised record.	Quantifies the potential financial loss associated with a data breach.	0	0	
KR04	# of Insider Threat Incidents	Highlights potential insider threats and the effectiveness of insider threat detection mechanisms.	0	0	
KR05	% of time systems are available and operational.	Reflects the resilience of the organization's IT infrastructure and the potential impact of downtime on security.	>99%	99%	

Squad name	Sum of LOC	# of vuln				#of vulns/1k Loc (total count)				
		Critical	High	Medium	Low	Critical	High	Medium	Low	Total
D&I	29448	0	5	16	54	0.00	0.17	0.54	1.83	2.55
PNP	42000	3	16	37	93	0.07	0.38	0.88	2.21	3.55
Connections	128200	0	24	139	215	0.00	0.19	1.08	1.68	2.95
LinkSDK	15000	0	0	22	3	0.00	0.00	1.47	0.20	1.67

Identified Opportunities for Improvement based on KPIs and KRIs values

- Identify which vulnerabilities are more frequently introduced as part of the code base and provide tailored security training to developers during next quarter

- Insecure Direct Object Reference
- For the offenders, provide additional security awareness training tailored on phishing. Disciplinary emails sent to line managers
- Discuss with line managers to increase awareness for the need of the security training among the engineer, in order to achieve a 100% participations rate.

Q2 2023

ID	KPI name	KPI Description	Q2 2023 Calculated value	Target value
S01	# of vulnerabilities failing remediation Security Team SLAs	Calculates the number of vulnerabilities that are failing to comply with the agreed remediation SLAs (per risk severity)	Critical - 0% High - 0% Medium - 64% Low - 75%	Critical - 0% High - 0 Medium - 50% Low -75%
S02	# of vulnerabilities per 1k lines of code	Calculates the number of vulnerabilities per 1k lines of code	See below table	See below table
S03	# of reported vulnerabilities disclosures not known internally	Calculates the number of reported vulnerabilities disclosure that were not previously identified internally	12 reported, 0 unknown	0 unknown
S04	% of software developers that have taken security training in the past quarter	% of software developers that have taken security training in the past 12 months	90%	100%
KR01	% of employees who click on phishing emails.	Measures the effectiveness of security awareness training and the organization's susceptibility to social engineering attacks.	20%	15%
KR02	# of unsuccessful login attempts or unauthorized	Highlights potential brute-force attacks or unauthorized access attempts	0	0

ID	KPI name	KPI Description	Q2 2023 Calculated value	Target value
	access incidents.			
KR03	The financial impact of a data breach per compromised record.	Quantifies the potential financial loss associated with a data breach.	0	0
KR04	# of Insider Threat Incidents	Highlights potential insider threats and the effectiveness of insider threat detection mechanisms.	0	0
KR05	% of time systems are available and operational.	Reflects the resilience of the organization's IT infrastructure and the potential impact of downtime on security.	>99%	99%

Identified Opportunities for Improvement based on KPIs and KRIs values

-
- SLA violation for ticket remediation:
 - Escalate this in the Security - EM Monthly meeting
 - Escalate this in the Prod-Eng Leadership Monthly meeting
 - Escalate with CTO/Head of Engineering
- Identify which vulnerabilities are more frequently introduced as part of the code base and provide tailored security training to developers during next quarter
 - Business Logic Vulnerabilities
- For the offenders, provide additional security awareness training tailored on phishing. Disciplinary emails sent to line managers
- Discuss with line managers to increase awareness for the need of the security training among the engineer, in order to achieve a 100% participations rate.

Q3 2023

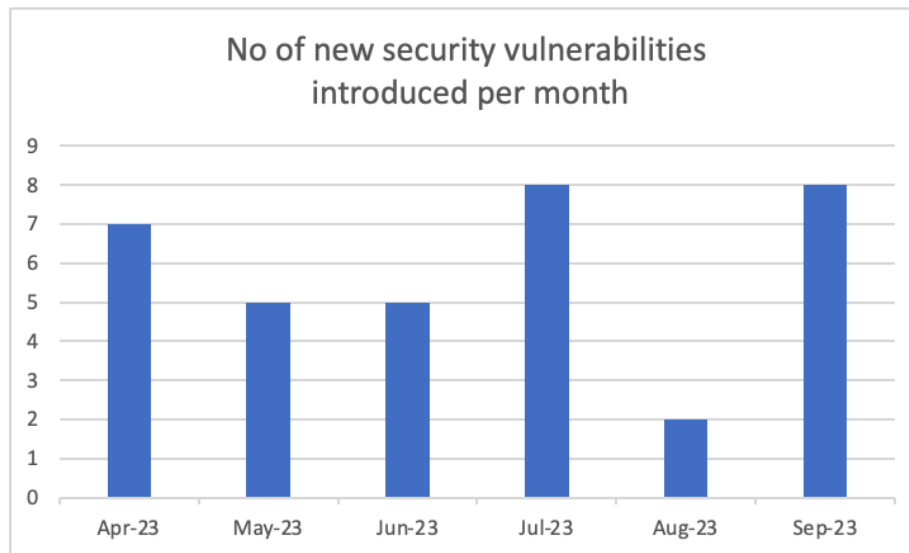
ID	KPI name	KPI Description	Q3 2023 Calculated value	Target value
S01	# of vulnerabilities failing remediation Security Team SLAs	Calculates the number of vulnerabilities that are failing to comply with the agreed remediation SLAs (per risk severity)	Critical - 0 High - 0 Medium -75% (76 out of 101) Low -75% (40 out of 53)	Critical - 0% High - 0% Medium - 50% Low -75%
S02	# of reported vulnerabilities disclosures not known internally	Calculates the number of reported vulnerabilities disclosure that were not previously identified internally	4 reported, 0 unknown	0 unknown
S03	% of software developers that have taken security training in the past quarter	% of software developers that have taken security training in the past 12 months	100%	100%
S04	Trend of the number of newly introduced security vulnerabilities	Trend of the number of newly introduced security vulnerabilities	See Bellow	Descending
KR01	% of employees who click on phishing emails.	Measures the effectiveness of security awareness training and the organization's susceptibility to social engineering attacks.	22%	15%
KR02	# of unsuccessful login attempts or unauthorized access incidents.	Highlights potential brute-force attacks or unauthorized access attempts	0	0
KR03	The financial impact of a data breach per compromised record.	Quantifies the potential financial loss associated with a data breach.	0	0
KR04	# of Insider Threat	Highlights potential insider threats and the effectiveness	0	0

ID	KPI name	KPI Description	Q3 2023 Calculated value	Target value
	Incidents	of insider threat detection mechanisms.		
KR05	% of time systems are available and operational.	Reflects the resilience of the organization's IT infrastructure and the potential impact of downtime on security.	>99%	99%
KR06	Risk appetite breaches	Tracks instances where actual risk exceeds the defined risk appetite. Any breach of risk appetite triggers a review of risk tolerance and mitigation strategies.	0	0
KR07	Progress of Risk Treatment Plan	Measures the completion status of risk treatment plans. Significant delays or incomplete plans may indicate a potential exposure to identified risks.	2 Risk Treatment plan ongoing, however not completed	2
KR08	Number of New Risks Identified	Measures the volume of newly identified risks within a specified period. A significant increase in the number of identified risks may indicate a change in the risk landscape.	3	N/A - Trend is analyzed
KR09	Number of Compliance Violations	Measures the frequency of non-compliance incidents with regulations or policies. An increase in violations may suggest a need for stronger compliance measures.	0	0
KR10	Regulatory Change Impact	Assesses the potential impact of upcoming regulatory changes on the organization's risk profile. Significant impacts may require adjustments to risk management strategies.	New KSA Data protection Law	N/A - Trend is analyzed

ID	KPI name	KPI Description	Q3 2023 Calculated value	Target value
KR11	Number of risk identifications initiatives	Assess company focus on identifying new risks	9 (as part of the SG02 - Security Design Review)	N/A - Trend is analyzed
KR12	Timeliness of RCC Committee Meetings	Measures the frequency and punctuality of cybersecurity committee meetings. Consistent delays or infrequent meetings may impact the committee's ability to provide timely guidance.	1 RCC in Q3	1
KRI13	Number of Decisions taken during RCC	Measures the effectiveness of the RCC and its role into the cybersecurity strategy of the company	5	N/A - Trend is analyzed
KR14	Third-Party Security Assessments Completion	Measures the completion rate of security assessments for third-party vendors and partners. Incomplete assessments may pose risks through insufficient knowledge of third-party cybersecurity postures.	6	N/A - Trend is analyzed
KR15	Trends in Security Incidents	Monitors trends in the number and severity of security incidents over time. Significant upward trends may indicate systemic issues in the cybersecurity program.	0 Incidents to be reported to SAMA	0
KR16	Number of new security initiatives	Monitors the focus on improving the future state of security for the company	3	N/A - Trend is analyzed
KR17	Incident Rate from Third-Party Dependencies	Tracks the frequency of cybersecurity incidents related to third-party dependencies. A high incident rate may indicate a need for enhanced third-party risk management.	0	0

ID	KPI name	KPI Description	Q3 2023 Calculated value	Target value
KR18	Number of identified security vulnerabilities from 3rd party penetration testing	Monitors the trend of security vulnerabilities identified during external pentesting	3 (used May pentesting results)	N/A -Trend is analyzed

S04 Value



Identified Opportunities for Improvement based on KPIs and KRIs values

- SLA violation for ticket remediation:
 - Escalate this in the Security - EM Monthly meeting
 - Escalate this in the Prod-Eng Leadership Monthly meeting
 - Escalate with CTO
- Identify which vulnerabilities are more frequently introduced as part of the code base and provide tailored security training to developers during next quarter
 - Insecure Session Management

- For the offenders, provide additional security awareness training tailored on phishing. Disciplinary emails sent to line managers
- Discuss with line managers to increase awareness for the need of the security training among the engineer, in order to achieve a 100% participations rate.
- Identify patterns in the no of newly introduces vulnerabilities per month
- Assess the impact and required changes of the new KSA Data Protection Law
- Re-assess the risk appetite for DR to a separate data center
- Review all existing risks from risk register to verify if there could be improvements in the treatment plan

Q4 2023

ID	KPI name	KPI Description	Q4 2023 Calculated value	Target value
KP01	# of vulnerabilities failing remediation Security Team SLAs	Calculates the number of vulnerabilities that are failing to comply with the agreed remediation SLAs (per risk severity)	Critical - 0 High - 0 Medium -40% Low -75% (40 out of 53)	Critical - 0% High - 0% Medium - 50% Low -75%
KP02	# of reported vulnerabilities disclosures not known internally	Calculates the number of reported vulnerabilities disclosure that were not previously identified internally	3 reported, 0 unknown	0 unknown
KP03	% of software developers that have taken security training in the past quarter	% of software developers that have taken security training in the past 12 months	100%	100%
KP04	# of policy breaches	# of employees breaches of Lean policies	0	0
KP05	% of employees acknowledging	% of employees that acknowledged the company policies	92%	95%

ID	KPI name	KPI Description	Q4 2023 Calculated value	Target value
	Company policies			
KP06	# of inconsistencies between Lean policies and applicable regulations and legislation	# of inconsistencies between Lean policies and applicable regulations and legislation	0	0
KP07	Policy reviews SLA breach	Policy reviews SLA breach	0	0
KR01	% of employees who click on phishing emails.	Measures the effectiveness of security awareness training and the organization's susceptibility to social engineering attacks.	19%	15%
KR02	# of unsuccessful login attempts or unauthorized access incidents.	Highlights potential brute-force attacks or unauthorized access attempts	0	0
KR03	The financial impact of a data breach per compromised record.	Quantifies the potential financial loss associated with a data breach.	0	0
KR04	# of Insider Threat Incidents	Highlights potential insider threats and the effectiveness of insider threat detection mechanisms.	0	0
KR05	% of time systems are available and operational.	Reflects the resilience of the organization's IT infrastructure and the potential impact of downtime on security.	>99%	99%
KR06	Risk appetite breaches	Tracks instances where actual risk exceeds the defined risk appetite. Any breach of risk appetite triggers a review of risk	0	0

ID	KPI name	KPI Description	Q4 2023 Calculated value	Target value
		tolerance and mitigation strategies.		
KR07	Progress of Risk Treatment Plan	Measures the completion status of risk treatment plans. Significant delays or incomplete plans may indicate a potential exposure to identified risks.	2 Risk Treatment plan ongoing, however not completed	2
KR08	Number of New Risks Identified	Measures the volume of newly identified risks within a specified period. A significant increase in the number of identified risks may indicate a change in the risk landscape.	3	N/A - Trend is analyzed
KR09	Number of Compliance Violations	Measures the frequency of non-compliance incidents with regulations or policies. An increase in violations may suggest a need for stronger compliance measures.	0	0
KR10	Regulatory Change Impact	Assesses the potential impact of upcoming regulatory changes on the organization's risk profile. Significant impacts may require adjustments to risk management strategies.	New KSA Data protection Law	N/A - Trend is analyzed
KR11	Number of risk identifications initiatives	Assess company focus on identifying new risks	9 (as part of the SG02 - Security Design Review + SG03 - Security Testing)	N/A - Trend is analyzed
KR12	Timeliness of RCC Committee Meetings	Measures the frequency and punctuality of cybersecurity committee meetings. Consistent delays or infrequent meetings may impact the committee's	1 RCC in Q4	1

ID	KPI name	KPI Description	Q4 2023 Calculated value	Target value
		ability to provide timely guidance.		
KRI13	Number of Decisions taken during RCC	Measures the effectiveness of the RCC and its role into the cybersecurity strategy of the company	5	N/A - Trend is analyzed
KRI14	Third-Party Security Assessments Completion	Measures the completion rate of security assessments for third-party vendors and partners. Incomplete assessments may pose risks through insufficient knowledge of third-party cybersecurity postures.	8	N/A - Trend is analyzed
KRI15	Trends in Security Incidents	Monitors trends in the number and severity of security incidents over time. Significant upward trends may indicate systemic issues in the cybersecurity program.	0 Incidents to be reported to SAMA	0
KRI16	Number of new security initiatives	Monitors the focus on improving the future state of security for the company	2	N/A - Trend is analyzed
KRI17	Incident Rate from Third-Party Dependencies	Tracks the frequency of cybersecurity incidents related to third-party dependencies. A high incident rate may indicate a need for enhanced third-party risk management.	0	0
KRI18	Number of identified security vulnerabilities from 3rd party penetration testing	Monitors the trend of security vulnerabilities identified during external pentesting	9 (used Dec pentesting results) - only Medium and Lows and are being tracked in JIRA	N/A -Trend is analyzed
KRI19	Number of implemented CR per quarter	Monitors the trend of implemented CR	43	Trend is to be calculated

ID	KPI name	KPI Description	Q4 2023 Calculated value	Target value
KR20	# of policy breaches			

Identified Opportunities for Improvement based on KPIs and KRIs values

- SLA violation for ticket remediation:
 - Escalate this in the Security - EM Monthly meeting
 - Escalate this in the Prod-Eng Leadership Monthly meeting
 - Escalate with CTO
- Identify which vulnerabilities are more frequently introduced as part of the code base and provide tailored security training to developers during next quarter
 - Insecure Session Management
- For the offenders, provide additional security awareness training tailored on phishing. Disciplinary emails sent to line managers
- Discuss with line managers to increase awareness for the need of the security training among the engineer, in order to achieve a 100% participations rate.
- Identify patterns in the no of newly introduces vulnerabilities per month
- Assess the impact and required changes of the new KSA Data Protection Law
- Re-assess the risk appetite for DR to a separate data center
- Review all existing risks from risk register to verify if there could be improvements in the treatment plan

Q1 2024

Shared with Stakeholders: Q1 2024 RCC Meeting

ID	KPI name	KPI Description	Q1 2024 Calculated value	Target value
KP01	# of vulnerabilities failing remediation	Calculates the number of vulnerabilities that are failing to comply with the agreed	Critical - 0 High - 0 Medium -40%	Critical - 0% High - 0%

ID	KPI name	KPI Description	Q1 2024 Calculated value	Target value
	Security Team SLAs	remediation SLAs (per risk severity)	Low -75% (40 out of 53)	Medium - 50% Low -75%
KP02	# of reported vulnerabilities disclosures not known internally	Calculates the number of reported vulnerabilities disclosure that were not previously identified internally	3 reported, 0 unknown	0 unknown
KP03	% of software developers that have taken security training in the past quarter	% of software developers that have taken security training in the past 12 months	100%	100%
KP04	# of policy breaches	# of employees breaches of Lean policies	0	0
KP05	% of employees acknowledging Company policies	% of employees that acknowledged the company policies	92%	95%
KP06	# of inconsistencies between Lean policies and standards and applicable regulations and legislation	# of inconsistencies between Lean policies and applicable regulations and legislation	0	0
KP07	Policy reviews SLA breach	Policy reviews SLA breach	0	0
KP08	# of access reviews	# of access reviews	8	8
KP09	# of employee security screening performed	# of employee security screening performed	5 (5 new employees)	Should be equal with the number of new employee
KP10	# of office card access reviews	# of office card access reviews	1	1
KP11	# of performed Architecture	# of performed Architecture Design Review	9	Should be equal with the

ID	KPI name	KPI Description	Q1 2024 Calculated value	Target value
	Design Review			total number of newly developed features
KP12	# of infrastructure vulnerabilities identified and fixed by Infra VA	# of infrastructure vulnerabilities identified and fixed by Infra VA	52	Trend is analyzed
KP13	# of secure erases performed	# of secure erases for employee laptops	3	Trend is analyzed
KP14	# of performed security due diligence for new IT Vendors	# of performed security due diligence for new IT Vendors	0	Trend is analyzed
KR01	% of employees who click on phishing emails.	Measures the effectiveness of security awareness training and the organization's susceptibility to social engineering attacks.	19%	15%
KR02	# of unsuccessful login attempts or unauthorized access incidents.	Highlights potential brute-force attacks or unauthorized access attempts	0	0
KR03	The financial impact of a data breach per compromised record.	Quantifies the potential financial loss associated with a data breach.	0	0
KR04	# of Insider Threat Incidents	Highlights potential insider threats and the effectiveness of insider threat detection mechanisms.	0	0

ID	KPI name	KPI Description	Q1 2024 Calculated value	Target value
KR05	% of time systems are available and operational.	Reflects the resilience of the organization's IT infrastructure and the potential impact of downtime on security.	>99%	99%
KR06	Risk appetite breaches	Tracks instances where actual risk exceeds the defined risk appetite. Any breach of risk appetite triggers a review of risk tolerance and mitigation strategies.	0	0
KR07	Progress of Risk Treatment Plan	Measures the completion status of risk treatment plans. Significant delays or incomplete plans may indicate a potential exposure to identified risks.	2 Risk Treatment plan ongoing, however not completed	2
KR08	Number of New Risks Identified	Measures the volume of newly identified risks within a specified period. A significant increase in the number of identified risks may indicate a change in the risk landscape.	3	N/A - Trend is analyzed
KR09	Number of Compliance Violations	Measures the frequency of non-compliance incidents with regulations or policies. An increase in violations may suggest a need for stronger compliance measures.	0	0
KR10	Regulatory Change Impact	Assesses the potential impact of upcoming regulatory changes on the organization's risk profile. Significant impacts may require adjustments to risk management strategies.	New KSA Data protection Law	N/A - Trend is analyzed
KR11	Number of risk identifications	Assess company focus on identifying new risks	9 (as part of the SG02 - Security	N/A - Trend is analyzed

ID	KPI name	KPI Description	Q1 2024 Calculated value	Target value
	initiatives		Design Review + SG03 - Security Testing)	
KR12	Timeliness of RCC Committee Meetings	Measures the frequency and punctuality of cybersecurity committee meetings. Consistent delays or infrequent meetings may impact the committee's ability to provide timely guidance.	1 RCC in Q1	1
KRI13	Number of Decisions taken during RCC	Measures the effectiveness of the RCC and its role into the cybersecurity strategy of the company	5	N/A - Trend is analyzed
KR14	Third-Party Security Assessments Completion	Measures the completion rate of security assessments for third-party vendors and partners. Incomplete assessments may pose risks through insufficient knowledge of third-party cybersecurity postures.	8	N/A - Trend is analyzed
KR15	Trends in Security Incidents	Monitors trends in the number and severity of security incidents over time. Significant upward trends may indicate systemic issues in the cybersecurity program.	0 Incidents to be reported to SAMA	0
KR16	Number of new security initiatives	Monitors the focus on improving the future state of security for the company	2	N/A - Trend is analyzed
KR17	Incident Rate from Third-Party Dependencies	Tracks the frequency of cybersecurity incidents related to third-party dependencies. A high incident rate may indicate a need for enhanced third-party risk management.	0	0

ID	KPI name	KPI Description	Q1 2024 Calculated value	Target value
KR18	Number of identified security vulnerabilities from 3rd party penetration testing	Monitors the trend of security vulnerabilities identified during external pentesting	9 (used Dec pentesting results) - only Medium and Lows and are being tracked in JIRA	N/A -Trend is analyzed
KR19	Number of implemented CR per quarter	Monitors the trend of implemented CR	43	Trend is to be calculated
KR20	# of true positive SOC alerts	Monitors the efficiency of the SOC alerts	19%	50%
KR21	# of SOC alerts	Monitors the threat landscape	173	Trend is analyzed
KR22	Number of emergency vs planned CR	Number of emergency vs planned CR	3 - Emergency 12 - Planned	Trend to be calculated
KR23	# of identified security vulnerabilities from internal testing	# of identified security vulnerabilities from internal testing	15	Trend is analyzed

Identified Opportunities for Improvement based on KPIs and KRIs values

- SLA violation for ticket remediation:
 - Escalate this in the Security - EM Monthly meeting
 - Escalate this in the Prod-Eng Leadership Monthly meeting
 - Escalate with CTO
- Identify which vulnerabilities are more frequently introduced as part of the code base and provide tailored security training to developers during next quarter
 - Insecure Session Management
- For the offenders, provide additional security awareness training tailored on phishing. Disciplinary emails sent to line managers
- Discuss with line managers to increase awareness for the need of the security training among the engineer, in order to achieve a 100% participations rate.

- Identify patterns in the no of newly introduces vulnerabilities per month
- Assess the impact and required changes of the new KSA Data Protection Law
- Re-assess the risk appetite for DR to a separate data center
- Review all existing risks from risk register to verify if there could be improvements in the treatment plan

Q2 2024

Shared with Stakeholders: Q2 2024 RCC Meeting

ID	KPI name	KPI Description	Q2 2024 Calculated value	Target value
KP01	# of vulnerabilities failing remediation Security Team SLAs	Calculates the number of vulnerabilities that are failing to comply with the agreed remediation SLAs (per risk severity)	Critical - 0 High - 0 Medium -52(out of 64) Low -17 (out of 24)	Critical - 0 High - 0 Medium - 50% Low -75%
KP02	# of reported vulnerabilities disclosures not known internally	Calculates the number of reported vulnerabilities disclosure that were not previously identified internally	1 reported(Low), 1 unknown	0 unknown
KP03	% of software developers that have taken security training in the past quarter	% of software developers that have taken security training in the past 12 months	100%	100%
KP04	# of policy breaches	# of employees breaches of Lean policies	0	0
KP05	% of employees acknowledging Company policies	% of employees that acknowledged the company policies	95%	95%
KP06	# of inconsistencies between Lean policies and applicable	# of inconsistencies between Lean policies and applicable regulations and legislation	0	0

ID	KPI name	KPI Description	Q2 2024 Calculated value	Target value
	regulations and legislation			
KP07	Policy reviews SLA breach	Policy reviews SLA breach	0	0
KP08	# of Access Reviews	# of Access Reviews	8	8
KP09	# of employee security screening performed	# of employee security screening performed	4 (4 new employees)	Should be equal with the number of new employee
KP10	# of physical security access review	# of physical security access review	1	1
KP11	# of performed Architecture Design Review	# of performed Architecture Design Review	5	Should be equal with the total number of newly developed features
KP12	# of infrastructure vulnerabilities identified and fixed by Infra VA	# of infrastructure vulnerabilities identified and fixed by Infra VA	1	Trend is analyzed
KP13	# of secure erases performed	# of secure erases for employee laptops	3 out of 3	Should be done for each laptop re-used
KP14	# of performed security due diligence for new IT Vendors	# of performed security due diligence for new IT Vendors	2 out of 2	Should be performed for each new IT vendor/tool/service
KP15	# of key management incidents (e.g., key compromise, unauthorized access).	Key management security incidents	0	0
KP16	% of systems publicly exposed using the latest TLS	Systems publicly exposed using latest TLS version	100%	100%

ID	KPI name	KPI Description	Q2 2024 Calculated value	Target value
	versions (1.2 or 1.3)			
KP17	% of mobile devices (phones/tablets) adhering to minimum security standards	Percentage of mobile devices (phones/tablets) adhering to minimum security standards (PIN, strong passcode, automatic lock).	100%	100%
KP18	% of company-issued devices with the Mobile Device Management (MDM) solution installed and active.	Percentage of company-issued devices with the Mobile Device Management (MDM) solution installed and active.	100%	100%
KP19	% of outsourcing projects compliant with SAMA regulations and approved by the cybersecurity function.	% of outsourcing projects compliant with SAMA regulations and approved by the cybersecurity function.	100%	100%
KP20	% of vendors meeting the SLAs related to cybersecurity controls and performance.	% of vendors meeting the SLAs related to cybersecurity controls and performance.	100%	100%
KP21	# of security initiatives part of the Security strategy, that have been implemented during a quarter	# of security initiatives part of the Security strategy, that have been implemented during a quarter	4 : ngfw, IPS/IDS, web content filtering, DR in GCP	3
KP22	% of all Lean's assets that are encrypted	Percentage of Lean's assets that are encrypted to ensure data protection	100%	100%

ID	KPI name	KPI Description	Q2 2024 Calculated value	Target value
		and compliance with encryption standard.		
KP23	% SLA breaches by outsourced vendors	Monitor and minimize SLA breaches by outsourced vendors to ensure consistent service quality	0%	0%
KP24	% of SLAs reviews passed for cloud services	% of SLAs reviews passed for cloud services	100%	100%
KP25	% of time cloud service providers meet their SLA	Track the percentage of time cloud service providers meet their SLA commitments	95%	95%
KP26	# of High /Critical CIS Benchmark violations	Tracks the number of High or Critical CIS Benchmark violations for Lean infrastructure	0	0
KP27	# of Violations found on privileged user accounts	Tracks the number of instances where privileged users were identified where there was no need or audit track	0	0
KP28	# of disposal incidents or violations	Tracks cases where devices or data were not disposed of securely, leading to potential security risks.	0	0
KP29	% of Lean infrastructure assets onboarded into SOC24x7	% of Lean infrastructure assets onboarded into SOC24x7	100%	100%
KR01	% of employees who click on phishing emails.	Measures the effectiveness of security awareness training and the organization's susceptibility to social engineering attacks.	27%	15%

ID	KPI name	KPI Description	Q2 2024 Calculated value	Target value
KR02	# of attempts to scan or inject malicious payloads	Highlights potential brute-force attacks or unauthorized access attempts	9	Trend is analyzed
KR03	The financial impact of a data breach per compromised record.	Quantifies the potential financial loss associated with a data breach.	0	0
KR04	# of Insider Threat Incidents	Highlights potential insider threats and the effectiveness of insider threat detection mechanisms.	0	0
KR05	% of time systems are available and operational.	Reflects the resilience of the organization's IT infrastructure and the potential impact of downtime on security.	>99%	99%
KR06	Risk appetite breaches	Tracks instances where actual risk exceeds the defined risk appetite. Any breach of risk appetite triggers a review of risk tolerance and mitigation strategies.	0	0
KR07	Progress of Risk Treatment Plan	Measures the completion status of risk treatment plans. Significant delays or incomplete plans may indicate a potential exposure to identified risks.	1 Risk Treatment plan ongoing, however not completed	2
KR08	Number of New Risks Identified	Measures the volume of newly identified risks within a specified period. A significant increase in the number of identified risks may indicate a change in the risk	2	N/A - Trend is analyzed

ID	KPI name	KPI Description	Q2 2024 Calculated value	Target value
		landscape.		
KR09	Number of Compliance Violations	Measures the frequency of non-compliance incidents with regulations or policies. An increase in violations may suggest a need for stronger compliance measures.	0	0
KR10	Regulatory Change Impact	Assesses the potential impact of upcoming regulatory changes on the organization's risk profile Significant impacts may require adjustments to risk management strategies.	PDPL	N/A - Trend is analyzed
KR11	Number of risk identifications initiatives	Assess company focus on identifying new risks	- PDPL - Data privacy risks - SAMA Anti-fraud requirements	N/A - Trend is analyzed
KR12	Timeliness of RCC Committee Meetings	Measures the frequency and punctuality of cybersecurity committee meetings. Consistent delays or infrequent meetings may impact the committee's ability to provide timely guidance.	1 RCC in Q2	1
KR13	Number of Decisions taken during RCC	Measures the effectiveness of the RCC and its role into the cybersecurity strategy of the company	4	N/A - Trend is analyzed
KR14	# of security incidents reported to SAMA	Monitors trends in the number and severity of security incidents over time. Significant upward trends may indicate systemic	0 Incidents to be reported to SAMA	0

ID	KPI name	KPI Description	Q2 2024 Calculated value	Target value
		issues in the cybersecurity program.		
KR15	Number of new security initiatives	Monitors the focus on improving the future state of security for the company	- Data exfiltration prevention - Next generation firewall - MDM for corporate phones	N/A - Trend is analyzed
KR16	Incident Rate from Third-Party Dependencies	Tracks the frequency of cybersecurity incidents related to third-party dependencies. A high incident rate may indicate a need for enhanced third-party risk management.	0	0
KR17	Number of identified security vulnerabilities from 3rd party penetration testing	Monitors the trend of security vulnerabilities identified during external pentesting	15 (used May pentesting results) - only Medium and Lows and are being tracked in JIRA	N/A -Trend is analyzed
KR18	Number of implemented CR per quarter	Monitors the trend of implemented CR	52	N/A -Trend is analyzed
KR29	# of true positive SOC alerts	Monitors the efficiency of the SOC alerts	15%	50%
KR20	# of SOC alerts	Monitors the threat landscape	197	Trend is analyzed
KR21	Number of emergency vs planned CR	Number of emergency vs planned CR	2 - Emergency 3 - Planned	Trend to be calculated
KR22	# of identified security vulnerabilities from internal testing	# of identified security vulnerabilities from internal testing	17	Trend is analyzed
KR23	# of actions conducted as	# of actions conducted as part of the Threat	0	Trend is analyzed

ID	KPI name	KPI Description	Q2 2024 Calculated value	Target value
	part of the Threat Intelligence feed	Intelligence feed		
KR24	# of required take down actions following Threat Intelligence and Brand Protection feed	# of required take down actions following Threat Intelligence and Brand Protection feed	0	Trend is analyzed

Identified Opportunities for Improvement based on KPIs and KRIs values

- SLA violation for ticket remediation (medium and Low)
 - Escalate this in the Security - EM Monthly meeting
 - Escalate this in the Prod-Eng Leadership Monthly meeting
 - Escalate with CTO
- Identify which vulnerabilities are more frequently introduced as part of the code base and provide tailored security training to developers during next quarter
 - File Upload vulnerabilities
- For the offenders, provide additional security awareness training tailored on phishing. Disciplinary emails sent to line managers
- Identify patterns in the no of newly introduces vulnerabilities per month
- Review all existing risks from risk register to verify if there could be improvements in the treatment plan
- Work on further fine-tuning SOC alerts

Q3 2024

Shared with Stakeholders: Q3 2024 RCC Meeting

ID	KPI name	KPI Description	Q3 2024 Calculated value	Target value
KP01	# of vulnerabilities failing remediation Security Team SLAs	Calculates the number of vulnerabilities that are failing to comply with the agreed remediation SLAs (per risk severity)	Critical - 0 High - 0 Medium -56(out of 62) Low -17 (out of 18)	Critical - 0 High - 0 Medium - 50% Low -75%
KP02	# of reported vulnerabilities disclosures not known internally	Calculates the number of reported vulnerabilities disclosure that were not previously identified internally	3 reported(Low), 0 unknown	0 unknown
KP03	% of software developers that have taken security training in the past quarter	% of software developers that have taken security training in the past 12 months	96%	100%
KP04	# of policy breaches	# of employees breaches of Lean policies	0	0
KP05	% of employees acknowledging Company policies	% of employees that acknowledged the company policies	95%	95%
KP06	# of inconsistencies between Lean policies and applicable regulations and legislation	# of inconsistencies between Lean policies and applicable regulations and legislation	0	0
KP07	Policy reviews SLA breach	Policy reviews SLA breach	0	0
KP08	# of Access Reviews	# of Access Reviews	12	8
KP09	# of employee security screening performed	# of employee security screening performed	12	Should be equal with the number of new employee
KP10	# of physical security access review	# of physical security access review	1	1

ID	KPI name	KPI Description	Q3 2024 Calculated value	Target value
KP11	# of performed Architecture Design Review	# of performed Architecture Design Review	14	Should be equal with the total number of newly developed features
KP12	# of infrastructure vulnerabilities identified and fixed by Infra VA	# of infrastructure vulnerabilities identified and fixed by Infra VA	34	Trend is analyzed
KP13	# of secure erases performed	# of secure erases for employee laptops	2 out of 2	Should be done for each laptop re-used
KP14	# of performed security due diligence for new IT Vendors	# of performed security due diligence for new IT Vendors	2 out of 2	Should be performed for each new IT vendor/tool/service
KP15	# of key management incidents (e.g., key compromise, unauthorized access).	Key management security incidents	0	0
KP16	% of systems publicly exposed using the latest TLS versions (1.2 or 1.3)	Systems publicly exposed using latest TLS version	100%	100%
KP17	% of mobile devices (phones/tablets) adhering to minimum security standards	Percentage of mobile devices (phones/tablets) adhering to minimum security standards (PIN, strong passcode, automatic lock).	100%	100%
KP18	% of company-issued devices with the Mobile Device Management	Percentage of company-issued devices with the Mobile Device Management (MDM)	100%	100%

ID	KPI name	KPI Description	Q3 2024 Calculated value	Target value
	(MDM) solution installed and active.	solution installed and active.		
KP19	% of outsourcing projects compliant with SAMA regulations and approved by the cybersecurity function.	% of outsourcing projects compliant with SAMA regulations and approved by the cybersecurity function.	100%	100%
KP20	% of vendors meeting the SLAs related to cybersecurity controls and performance.	% of vendors meeting the SLAs related to cybersecurity controls and performance.	100%	100%
KP21	# of security initiatives part of the Security strategy, that have been implemented during a quarter	# of security initiatives part of the Security strategy, that have been implemented during a quarter	3 : CIS benchmark, DLP, SOC 24x7 change	3
KP22	% of all Lean's assets that are encrypted	Percentage of Lean's assets that are encrypted to ensure data protection and compliance with encryption standard.	100%	100%
KP23	% SLA breaches by outsourced vendors	Monitor and minimize SLA breaches by outsourced vendors to ensure consistent service quality	0%	0%
KP24	% of SLAs reviews passed for cloud services	% of SLAs reviews passed for cloud services	100%	100%
KP25	% of time cloud service providers meet their SLA	Track the percentage of time cloud service providers meet their SLA commitments	95%	95%

ID	KPI name	KPI Description	Q3 2024 Calculated value	Target value
KP26	# of High /Critical CIS Benchmark violations	Tracks the number of High or Critical CIS Benchmark violations for Lean infrastructure	0	0
KP27	# of Violations found on privileged user accounts	Tracks the number of instances where privileged users were identified where there was no need or audit track	0	0
KP28	# of disposal incidents or violations	Tracks cases where devices or data were not disposed of securely, leading to potential security risks.	0	0
KP29	% of Lean infrastructure assets onboarded into SOC24x7	% of Lean infrastructure assets onboarded into SOC24x7	100%	100%
KR01	% of employees who click on phishing emails.	Measures the effectiveness of security awareness training and the organization's susceptibility to social engineering attacks.	44%	15%
KR02	# of attempts to scan or inject malicious payloads	Highlights potential brute-force attacks or unauthorized access attempts	172	Trend is analyzed
KR03	The financial impact of a data breach per compromised record.	Quantifies the potential financial loss associated with a data breach.	0	0
KR04	# of Insider Threat Incidents	Highlights potential insider threats and the effectiveness of insider threat detection mechanisms.	0	0

ID	KPI name	KPI Description	Q3 2024 Calculated value	Target value
KR05	% of time systems are available and operational.	Reflects the resilience of the organization's IT infrastructure and the potential impact of downtime on security.	>99%	99%
KR06	Risk appetite breaches	Tracks instances where actual risk exceeds the defined risk appetite. Any breach of risk appetite triggers a review of risk tolerance and mitigation strategies.	0	0
KR07	Progress of Risk Treatment Plan	Measures the completion status of risk treatment plans. Significant delays or incomplete plans may indicate a potential exposure to identified risks.	1 Risk Treatment plan ongoing, however not completed	2
KR08	Number of New Risks Identified	Measures the volume of newly identified risks within a specified period. A significant increase in the number of identified risks may indicate a change in the risk landscape.	4	N/A - Trend is analyzed
KR09	Number of Compliance Violations	Measures the frequency of non-compliance incidents with regulations or policies. An increase in violations may suggest a need for stronger compliance measures.	0	0
KR10	Regulatory Change Impact	Assesses the potential impact of upcoming regulatory changes on the organization's risk profile. Significant impacts may require adjustments to	PDPL	N/A - Trend is analyzed

ID	KPI name	KPI Description	Q3 2024 Calculated value	Target value
		risk management strategies.		
KR11	Number of risk identifications initiatives	Assess company focus on identifying new risks	N/A	N/A - Trend is analyzed
KR12	Timeliness of RCC Committee Meetings	Measures the frequency and punctuality of cybersecurity committee meetings. Consistent delays or infrequent meetings may impact the committee's ability to provide timely guidance.	1 RCC in Q3	1
KR13	Number of Decisions taken during RCC	Measures the effectiveness of the RCC and its role into the cybersecurity strategy of the company	3	N/A - Trend is analyzed
KR14	# of security incidents reported to SAMA	Monitors trends in the number and severity of security incidents over time. Significant upward trends may indicate systemic issues in the cybersecurity program.	0 Incidents to be reported to SAMA	0
KR15	Number of new security initiatives	Monitors the focus on improving the future state of security for the company	- Data exfiltration prevention	N/A - Trend is analyzed
KR16	Incident Rate from Third-Party Dependencies	Tracks the frequency of cybersecurity incidents related to third-party dependencies. A high incident rate may indicate a need for enhanced third-party risk management.	0	0
KR17	Number of identified security	Monitors the trend of security vulnerabilities	21 (used May pentesting results) - only Medium and	N/A -Trend is analyzed

ID	KPI name	KPI Description	Q3 2024 Calculated value	Target value
	vulnerabilities from 3rd party penetration testing	identified during external pentesting	Lows and are being tracked in JIRA	
KR18	Number of implemented CR per quarter	Monitors the trend of implemented CR	43	N/A -Trend is analyzed
KR29	# of true positive SOC alerts	Monitors the efficiency of the SOC alerts	23%	50%
KR20	# of SOC alerts	Monitors the threat landscape	140	Trend is analyzed
KR21	Number of emergency vs planned CR	Number of emergency vs planned CR	1 - Emergency 5 - Planned	Trend to be calculated
KR22	# of identified security vulnerabilities from internal testing	# of identified security vulnerabilities from internal testing	18	Trend is analyzed
KR23	# of actions conducted as part of the Threat Intelligence feed	# of actions conducted as part of the Threat Intelligence feed	0	Trend is analyzed
KR24	# of required take down actions following Threat Intelligence and Brand Protection feed	# of required take down actions following Threat Intelligence and Brand Protection feed	0	Trend is analyzed

Identified Opportunities for Improvement based on KPIs and KRIs values

- SLA violation for ticket remediation (medium and Low)
 - Escalate this in the Security - EM Monthly meeting
 - Escalate this in the Prod-Eng Leadership Monthly meeting

- Escalate with CTO
- Identify which vulnerabilities are more frequently introduced as part of the code base and provide tailored security training to developers during next quarter
 - File Upload vulnerabilities
- For the offenders, provide additional security awareness training tailored on phishing. Disciplinary emails sent to line managers
- Identify patterns in the no of newly introduces vulnerabilities per month
- Review all existing risks from risk register to verify if there could be improvements in the treatment plan
- Work on further fine-tuning SOC alerts

Q4 2024

Shared with Stakeholders: Q4 2024 RCC Meeting

ID	KPI name	KPI Description	Q4 2024 Calculated value	Target value
KP01	# of vulnerabilities failing remediation Security Team SLAs	Calculates the number of vulnerabilities that are failing to comply with the agreed remediation SLAs (per risk severity)	Critical - 0 High - 0 Medium -61(out of 67) Low -14 (out of 26)	Critical - 0 High - 0 Medium - 50% Low -75%
KP02	# of reported vulnerabilities disclosures not known internally	Calculates the number of reported vulnerabilities disclosure that were not previously identified internally	2 reported(Low), 0 unknown	0 unknown
KP03	% of software developers that have taken security training in the past quarter	% of software developers that have taken security training in the past 12 months	44%	100%
KP04	# of policy breaches	# of employees breaches of Lean	0	0

ID	KPI name	KPI Description	Q4 2024 Calculated value	Target value
		policies		
KP05	% of employees acknowledging Company policies	% of employees that acknowledged the company policies	94%	95%
KP06	# of inconsistencies between Lean policies and applicable regulations and legislation	# of inconsistencies between Lean policies and applicable regulations and legislation	0	0
KP07	Policy reviews SLA breach	Policy reviews SLA breach	0	0
KP08	# of Access Reviews	# of Access Reviews	11	8
KP09	# of employee security screening performed	# of employee security screening performed	15	Should be equal with the number of new employee
KP10	# of physical security access review	# of physical security access review	1	1
KP11	# of performed Architecture Design Review	# of performed Architecture Design Review	7	Should be equal with the total number of newly developed features
KP12	# of infrastructure vulnerabilities identified and fixed by Infra VA	# of infrastructure vulnerabilities identified and fixed by Infra VA	124	Trend is analyzed
KP13	# of secure erases performed	# of secure erases for employee laptops	5 out of 5	Should be done for each laptop re-used
KP14	# of performed security due diligence for new IT Vendors	# of performed security due diligence for new IT Vendors	1	Should be performed for each new IT vendor/tool/service
KP15	# of key management incidents (e.g., key compromise, unauthorized access).	Key management security incidents	0	0

ID	KPI name	KPI Description	Q4 2024 Calculated value	Target value
KP16	% of systems publicly exposed using the latest TLS versions (1.2 or 1.3)	Systems publicly exposed using latest TLS version	100%	100%
KP17	% of mobile devices (phones/tablets) adhering to minimum security standards	Percentage of mobile devices (phones/tablets) adhering to minimum security standards (PIN, strong passcode, automatic lock).	100%	100%
KP18	% of company-issued devices with the Mobile Device Management (MDM) solution installed and active.	Percentage of company-issued devices with the Mobile Device Management (MDM) solution installed and active.	100%	100%
KP19	% of outsourcing projects compliant with SAMA regulations and approved by the cybersecurity function.	% of outsourcing projects compliant with SAMA regulations and approved by the cybersecurity function.	100%	100%
KP20	% of vendors meeting the SLAs related to cybersecurity controls and performance.	% of vendors meeting the SLAs related to cybersecurity controls and performance.	100%	100%
KP21	# of security initiatives part of the Security strategy, that have been implemented during a quarter	# of security initiatives part of the Security strategy, that have been implemented during a quarter	EDR, WAF CloudFlare	3
KP22	% of all Lean's assets that are encrypted	Percentage of Lean's assets that are encrypted to ensure data	100%	100%

ID	KPI name	KPI Description	Q4 2024 Calculated value	Target value
		protection and compliance with encryption standard.		
KP23	% SLA breaches by outsourced vendors	Monitor and minimize SLA breaches by outsourced vendors to ensure consistent service quality	0%	0%
KP24	% of SLAs reviews passed for cloud services	% of SLAs reviews passed for cloud services	100%	100%
KP25	% of time cloud service providers meet their SLA	Track the percentage of time cloud service providers meet their SLA commitments	100%	95%
KP26	# of High /Critical CIS Benchmark violations	Tracks the number of High or Critical CIS Benchmark violations for Lean infrastructure	0	0
KP27	# of Violations found on privileged user accounts	Tracks the number of instances where privileged users were identified where there was no need or audit track	0	0
KP28	# of disposal incidents or violations	Tracks cases where devices or data were not disposed of securely, leading to potential security risks.	0	0
KP29	% of Lean infrastructure assets onboarded into SOC24x7	% of Lean infrastructure assets onboarded into SOC24x7	100%	100%
KR01	% of employees who click on phishing emails.	Measures the effectiveness of security awareness training and the	6%	15%

ID	KPI name	KPI Description	Q4 2024 Calculated value	Target value
		organization's susceptibility to social engineering attacks.		
KR02	# of attempts to scan or inject malicious payloads	Highlights potential brute-force attacks or unauthorized access attempts	58	Trend is analyzed
KR03	The financial impact of a data breach per compromised record.	Quantifies the potential financial loss associated with a data breach.	0	0
KR04	# of Insider Threat Incidents	Highlights potential insider threats and the effectiveness of insider threat detection mechanisms.	0	0
KR05	% of time systems are available and operational.	Reflects the resilience of the organization's IT infrastructure and the potential impact of downtime on security.	>99%	99%
KR06	# of Risk appetite breaches	Tracks instances where actual risk exceeds the defined risk appetite. Any breach of risk appetite triggers a review of risk tolerance and mitigation strategies.	0	0
KR07	Progress of Risk Treatment Plan	Measures the completion status of risk treatment plans. Significant delays or incomplete plans may indicate a potential exposure to identified risks.	4 Risk treatment plans completed : - Implementation of AV tools -SCA tool -laac Tool -private code repository and	2

ID	KPI name	KPI Description	Q4 2024 Calculated value	Target value
			Threat Intelligence services	
KR08	Number of New Risks Identified	Measures the volume of newly identified risks within a specified period. A significant increase in the number of identified risks may indicate a change in the risk landscape.	4	N/A - Trend is analyzed
KR09	Number of Compliance Violations	Measures the frequency of non-compliance incidents with regulations or policies. An increase in violations may suggest a need for stronger compliance measures.	0	0
KR10	Regulatory Change Impact	Assesses the potential impact of upcoming regulatory changes on the organization's risk profile. Significant impacts may require adjustments to risk management strategies.	PDPL	N/A - Trend is analyzed
KR11	Number of risk identifications initiatives	Assess company focus on identifying new risks	2 - for 2 new products: -Payouts -Refunds	N/A - Trend is analyzed
KR12	Timeliness of RCC Committee Meetings	Measures the frequency and punctuality of cybersecurity	1 RCC in Q4	1

ID	KPI name	KPI Description	Q4 2024 Calculated value	Target value
		committee meetings. Consistent delays or infrequent meetings may impact the committee's ability to provide timely guidance.		
KRI13	Number of Decisions taken during RCC	Measures the effectiveness of the RCC and its role into the cybersecurity strategy of the company	4	N/A - Trend is analyzed
KRI14	# of security incidents reported to SAMA	Monitors trends in the number and severity of security incidents over time. Significant upward trends may indicate systemic issues in the cybersecurity program.	0 Incidents to be reported to SAMA	0
KRI15	Number of new security initiatives	Monitors the focus on improving the future state of security for the company	- Commercial EDR - Cloudflare WAF	N/A - Trend is analyzed
KRI16	Incident Rate from Third-Party Dependencies	Tracks the frequency of cybersecurity incidents related to third-party dependencies. A high incident rate may indicate a need for enhanced third-party risk management.	0	0
KRI17	Number of identified security vulnerabilities from 3rd party penetration testing	Monitors the trend of security vulnerabilities identified during external pentesting	4 (used Nov pentesting results) - only Lows and are being tracked in JIRA	N/A -Trend is analyzed

ID	KPI name	KPI Description	Q4 2024 Calculated value	Target value
KR18	Number of implemented CR per quarter	Monitors the trend of implemented CR	29	N/A -Trend is analyzed
KR29	# of true positive SOC alerts	Monitors the efficiency of the SOC alerts	19%	50%
KR20	# of SOC alerts	Monitors the threat landscape	860	Trend is analyzed
KR21	Number of emergency vs planned CR	Number of emergency vs planned CR	0 - Emergency 12 - Planned	Trend to be calculated
KR22	# of identified security vulnerabilities from internal testing	# of identified security vulnerabilities from internal testing	14	Trend is analyzed
KR23	# of actions conducted as part of the Threat Intelligence feed	# of actions conducted as part of the Threat Intelligence feed	3	Trend is analyzed
KR24	# of required take down actions following Threat Intelligence and Brand Protection feed	# of required take down actions following Threat Intelligence and Brand Protection feed	1	Trend is analyzed

Identified Opportunities for Improvement based on KPIs and KRIs values

- SLA violation for ticket remediation (medium and Low)
 - Escalate this in the Security - EM Monthly meeting
 - Escalate this in the Prod-Eng Leadership Monthly meeting
 - Escalate with CTO
- Work closely with Product Managers to identify project management risks earlier
- For the offenders, provide additional security awareness training tailored on phishing. Disciplinary emails sent to line managers
- Consider opening a bug bounty program

- Review all existing risks from risk register to verify if there could be improvements in the treatment plan
- Work on further fine-tuning SOC alerts